

Control de Asistencia

NOM-037-STPS-2023

VERSION 2.2 - PRODUCCION

Descripcion Completa del Proyecto

Sistema web de control de asistencia laboral con geolocalizacion, codigos QR dinamicos, gestion de descansos y reportes NOM-037.

Documento	Descripcion Completa del Proyecto
Version	2.2 (Produccion)
Framework	Next.js 16 + TypeScript 5
Base de datos	Supabase PostgreSQL
Deploy	Vercel (control-asistencia-v22.vercel.app)
Cumplimiento	NOM-037-STPS-2023 - LFT Mexico

Descripcion del Proyecto

Control de Asistencia es un sistema web completo de control de asistencia laboral diseñado para cumplir con la **NOM-037-STPS-2023** (Norma Oficial Mexicana de Condiciones de Seguridad y Salud en el Trabajo - Trabajo a Distancia y Teletrabajo). El sistema permite registrar y monitorear la asistencia de empleados con geolocalización, codigos QR dinamicos, gestion de descansos y generacion de reportes, todo bajo un marco de auditoria inmutable.

La version 2.2 incorpora mejoras significativas de seguridad y funcionalidad: autenticacion robusta con NextAuth.js v4 (JWT firmado + MFA TOTP), notificaciones en tiempo real via WebSockets/Socket.io, y un sistema de control de acceso basado en roles (RBAC) de 4 niveles con el nuevo rol Supervisor.

Tecnologias Utilizadas

Categoria	Tecnologia	Detalle
Framework	Next.js 16 (App Router)	Output standalone, SSR/CSR
Lenguaje	TypeScript 5	Strict mode
Frontend	React 19 + Tailwind CSS 4	shadcn/ui New York style
Animaciones	Framer Motion	Transiciones, hover effects
Estado	Zustand 5 + TanStack Query	Auth store + Server state
Base de datos	Supabase PostgreSQL	Prisma ORM 6 nativo
Autenticacion	NextAuth.js v4 (JWT)	Firmado HMAC-SHA512 + MFA TOTP
Encriptacion	bcryptjs + AES-256-GCM	Hash passwords + secreto MFA
Codigos QR	qrcode + crypto	HMAC-SHA256, 5 min expiracion
Tiempo real	Socket.io	Mini-service puerto 3003
Fechas	date-fns	America/Mexico_City
Export	exceljs	XLSX multi-hoja + CSV
Deploy	Vercel	Region iad1, build automatico

Funcionalidades Implementadas

1. Autenticacion Robusta (Fase 1 - Mejorada)

El sistema migro de cookies base64 sin firma a **NextAuth.js v4 con JWT firmado**. El token esta encriptado con NEXTAUTH_SECRET usando AES-256-GCM, lo que hace imposible la falsificacion de sesiones. Adicionalmente, se implemento MFA TOTP (RFC 6238) opcional para cuentas de administrador, compatible con Google Authenticator, Authy y 1Password.

Feature	Estado	Detalle
Login con email + password	✓ Implementado	bcryptjs + lockout 5 intentos
Login rapido (kiosco)	✓ Implementado	Botones sin contraseña
Login con QR dinamico	✓ Implementado	HMAC-SHA256, 5 min
JWT firmado (NextAuth)	★ NUEVO v2.2	AES-256-GCM, rotacion 30 min
MFA TOTP opcional	★ NUEVO v2.2	otplib + 10 backup codes
Cookie HttpOnly + SameSite	★ NUEVO v2.2	Proteccion CSRF + XSS

2. Panel de Administrador (9 vistas)

Vista	Funcionalidad
Dashboard	KPIs en tiempo real, tabla de asistencia, resumen de descansos, ausentes
Empleados	CRUD completo, QR individual, transferencia, horarios L-V
Sucursales	CRUD con geofencing (Haversine), codigo de local (Local 261)
Asistencia	Historial con filtros, correccion manual, justificaciones, CSV
Reportes	5 tipos: Diario, HE, Ausencias, Incidencias, Comparativo - CSV + XLSX
Vacaciones	Solicitudes, aprobacion, balance automatico, tipos multiples
Auditoria	Log inmutable con IP, user-agent, paginacion, filtros
Terminal QR	Codigos QR dinamicos con auto-refresh cada 4 min
Empresa	Razon social, RFC, registro patronal (NOM-037)

3. Panel de Empleado (4 vistas)

Vista	Funcionalidad
Asistencia	Check-in/out GPS o QR, descanso 30 min con timer visual, mapa
Historial	Registro propio con filtros y descarga CSV

Vista	Funcionalidad
Vacaciones	Balance de días, solicitud y cancelacion
Mi QR	Codigo QR personal estatico para descarga PNG

Novedades de la Version 2.2 (Fase 1)

La version 2.2 introduce tres mejoras fundamentales que elevan el sistema al siguiente nivel de seguridad, usabilidad y escalabilidad.

A. NextAuth.js v4 - Seguridad Robusta

Se migro del sistema de cookies base64 sin firma a **NextAuth.js v4 con JWT firmado**. El token de sesion ahora esta encriptado con AES-256-GCM usando NEXTAUTH_SECRET, lo que elimina el riesgo de falsificacion de sesiones. Se mantienen los tres flujos de login (password, QR dinamico, quick-login) que ahora emiten JWT firmados. Adicionalmente, se implemento **MFA TOTP** opcional para administradores, con generacion de backup codes y encriptacion del secreto a nivel aplicacion.

B. WebSockets/Socket.io - Tiempo Real

Se implemento un mini-service independiente con Socket.io (puerto 3003) que permite al panel de administrador recibir notificaciones instantaneas cuando un empleado hace check-in, check-out, inicia/termina descanso, o solicita vacaciones. El frontend usa el hook **useRealtime** que invalida automaticamente las queries de TanStack Query, eliminando la necesidad de refresco manual.

Evento	Trigger	Destinatario
attendance:check-in	POST /api/attendance/check-in	Admins de la sucursal
attendance:check-out	POST /api/attendance/check-out	Admins de la sucursal
attendance:break-start	POST /api/attendance/meal-start	Admins de la sucursal
attendance:break-end	POST /api/attendance/meal-end	Admins de la sucursal
vacation:requested	POST /api/vacations	Admins de la sucursal
vacation:status	PUT /api/vacations/[id]	Admins + empleado

C. Rol Supervisor - RBAC de 4 Niveles

Se anadio el rol **SUPERVISOR** al sistema de control de acceso basado en roles. Este rol es intermedio entre Admin de Sucursal y Empleado: puede **ver** asistencia, empleados, reportes y auditoria de su sucursal, pero **no puede** crear/editar/eliminar empleados, aprobar vacaciones, corregir registros, ni generar QR.

Rol	Alcance	Permisos clave
GENERAL_ADMIN	Global	Todo: CRUD, reportes comparativos, empresa, usuarios
SUCURSAL_ADMIN	Su sucursal	CRUD empleados, aprobar vacaciones, corregir, QR
SUPERVISOR	Su sucursal	Solo lectura: dashboard, asistencia, reportes, auditoria
EMPLOYEE	Propio	Check-in/out, historial, vacaciones, Mi QR

Cumplimiento NOM-037

El sistema esta disenado para cumplir con los requisitos de la NOM-037-STPS-2023 y la Ley Federal del Trabajo de Mexico. Los registros son inmutables, la geolocalizacion es obligatoria, y cada accion queda registrada en la bitacora de auditoria.

Requisito	Implementacion
Registros inmutables	isLocked: true - no se pueden alterar una vez creados
Geolocalizacion obligatoria	Lat/long en check-in/out + geofencing Haversine
Auditoria completa	Cada accion con IP, user-agent, timestamp, usuario
Sistema de justificaciones	Para registros inconsistentes (PENDING/APPROVED/REJECTED)
Calculo de horas extra	Automatico segun horario, historico 90 dias
Tolerancia configurable	Por sucursal: entrada, salida, descanso
Descanso de 30 min	Para jornadas >=8h, con deteccion de exceso
Datos de empresa	Razon social, RFC, registro patronal en reportes
Dias feriados	Calendario de dias no laborables

Reportes y Exportacion

El sistema genera 5 tipos de reportes con exportacion a CSV y XLSX (multi-hoja con Portada, Datos y Resumen). Todos los reportes respetan el scope de sucursal del usuario.

Reporte	Contenido	Acceso
Diario	Asistencia por fecha con desglose por sucursal	Todos los admins
Horas Extra	Calculo automatico, historico 90 dias, por empleado	Todos los admins
Ausencias	Faltas justificadas e injustificadas	Todos los admins
Incidencias	Consolidado: faltas, retardos, salidas anticipadas, HE	Todos los admins
Comparativo	Comparativo entre sucursales con attendanceRate	Solo GENERAL_ADMIN

Resumen en Numeros

Metrica	Valor
Modelos de base de datos	10 (User, Employee, Company, Sucursal, WorkSchedule, AttendanceRecord, Vacation, Holiday, AuditLog, DynamicQR)
Rutas API	~70 endpoints en 55 archivos
Roles de usuario	4 (GENERAL_ADMIN, SUCURSAL_ADMIN, SUPERVISOR, EMPLOYEE)
Tipos de reportes	5 (Diario, Horas Extra, Ausencias, Incidencias, Comparativo)
Vistas panel admin	9 (Dashboard, Empleados, Sucursales, Asistencia, Reportes, Vacaciones, Auditoria, QR, Empresa)
Vistas panel empleado	4 (Asistencia, Historial, Vacaciones, Mi QR)
Componentes shadcn/ui	40+
Eventos Socket.io	6 (check-in, check-out, break-start/end, vacation-requested/status)
URL produccion	control-asistencia-v22.vercel.app

Roadmap de Evolucion

El sistema tiene una base solida y funcional para cumplimiento NOM-037. Las siguientes mejoras estan identificadas como siguientes pasos para escalar como producto SaaS.

Prioridad	Area	Estado
Critico	NextAuth.js v4 con JWT + MFA	✓ Completado v2.2
Critico	WebSockets tiempo real (Socket.io)	✓ Completado v2.2
Critico	RBAC granular (4 roles con Supervisor)	✓ Completado v2.2
Importante	App movil PWA instalable	✗ Pendiente
Importante	Notificaciones push/email	✗ Pendiente
Importante	Integracion con nomina (SAP, Odoo)	✗ Pendiente
Importante	Dashboard analytics avanzado	■ Parcial
Deseable	Turnos rotativos	✗ Pendiente
Deseable	Modo offline (Service Worker)	✗ Pendiente
Deseable	Multi-tenant SaaS	✗ Pendiente
Deseable	CI/CD GitHub Actions	✗ Pendiente

Prioridad	Area	Estado
Deseable	API publica (Swagger/OpenAPI)	✗ Pendiente

El proyecto tiene una base solida y funcional para cumplimiento NOM-037. La Fase 1 (autenticacion robusta, tiempo real, RBAC granular) esta completa. Los pilares clave para el siguiente nivel son: app movil/PWA, notificaciones, integracion con nomina, y multi-tenant SaaS.